SC-900 Supernotat

Microsoft Security, Compliance and Identity Fundamentals

Komplett eksamensnotat på norsk. Fire kilder er slått sammen til ett dokument: egne notater, eksamensnotater, notater i klartekst og studieguide (Srikanth Thota, feb 2026).

Domene	Vekt	Kapittel
Konsepter: sikkerhet, compliance, identitet	10–15 %	1
Identitet i Microsoft Entra	25–30 %	2
Sikkerhetsløsninger i Microsoft	35–40 %	3
Compliance-løsninger i Microsoft	20–25 %	4

Sist oppdatert oktober 2026. Lisenskrav og preview-status endres: sjekk Microsoft Learn før eksamen.

Innhold

Slik bruker du dette dokumentet 3

Jukselapp: scenario → svar 4

1. Grunnleggende konsepter 6

2. Identitet i Microsoft Entra 8

3. Microsofts sikkerhetsløsninger 13

4. Microsofts compliance-løsninger 20

5. Forvekslingspar (eksamensfeller) 24

6. Hurtigreferanse til eksamensdagen 24

7. Selvtest 25

8. Avvik mellom kildene og hva du bør sjekke 27

Slik bruker du dette dokumentet

Dette er en samling av fire kilder: dine egne notater, eksamensnotatene, notatene i klartekst og studieguiden til Srikanth Thota (feb 2026). Overlappende innhold er slått sammen, og der kildene sier ulike ting er det markert (se **kapittel 8**). Alt som **ikke** sto i noen av kildene, men som ofte er med på eksamen, står i oransje **TILLEGG**-bokser.

Domene	Vekt	Kapittel
Konsepter: sikkerhet, compliance, identitet	10–15 %	1
Identitet i Microsoft Entra	25–30 %	2
Sikkerhetsløsninger i Microsoft	**35–40 %**	**3**
Compliance-løsninger i Microsoft	20–25 %	4

Tegnforklaring

HUSK Viktig å huske.

EKSAMEN Typisk eksamensspørsmål.

ANALOGI Huskehjelp.

PASS OPP Vanlig felle.

TILLEGG Ikke i dine kilder, fra generell kunnskap. Sjekk mot Microsoft Learn.

Strategi

- SC-900 er **fundamentals**: spørsmålene er «hva gjør dette?» og «hvilken tjeneste passer her?», ikke dyp konfigurasjon.
- **Domene 3 teller mest.** Legg mest tid der.
- Eksamen elsker **forvekslingspar** (alert vs. incident, SIEM vs. XDR, DLP vs. Insider Risk). De står samlet i kapittel 5.
- På scenariospørsmål: finn **nøkkelordet** i oppgaven og slå opp i jukselappen under.
- Lisenskrav og preview-status endres (Agent ID, Security Copilot, Blueprints). **Sjekk Microsoft Learn før eksamen.**
- Bestått er 700 av 1000 poeng (sjekk Learn). Ikke bruk for mye tid her hvis CCNA er hovedprioritet.

Jukselapp: scenario → svar

Les oppgaven, finn nøkkelordet, finn tjenesten. Dette er den mest effektive siden å repetere dagen før eksamen.

Identitet (Entra)

Hvis oppgaven sier…	Svar
Bekrefte HVEM du er / HVA du har tilgang til	AuthN / AuthZ
Regler av typen «hvis X, så Y» ved innlogging	Conditional Access (P1)
Admin-rolle bare ved behov, tidsbegrenset	PIM (P2)
Lekkede passord, umulig reise, risikable innlogginger	Entra ID Protection (P2)
Periodisk gjennomgang av hvem som har tilgang	Access reviews
Automatisk tilgang når noen begynner / bytter / slutter	Lifecycle workflows
Tilgangspakke med godkjenning og utløpsdato	Entitlement management
Partnere/gjester samarbeider med ansatte	External ID: B2B
Kunder logger inn i din egen app	External ID: external tenant (CIAM)
Synkronisere on-prem AD til sky	Entra Connect
Bruker nullstiller passord selv	SSPR (hybrid: password writeback)
Tilgang til interne apper uten VPN	Entra Private Access
Sikker tilgang til internett/SaaS, webfiltrering	Entra Internet Access
Digitale legitimasjoner du eier selv	Verified ID
Identitet og styring for AI-agenter	Entra Agent ID
Azure-ressurs får identitet uten passord i koden	Managed identity

Sikkerhet

Hvis oppgaven sier…	Svar
Koble varsler fra e-post, identitet og enhet til én hendelse	Defender XDR
SIEM + SOAR, samle logger, playbooks	Microsoft Sentinel
Phishing og skadelige vedlegg i e-post/Teams	Defender for Office 365
Beskytte PC-er/servere (EDR), isolere enhet	Defender for Endpoint
Mistenkelig aktivitet i on-prem AD, lateral movement	Defender for Identity
Oversikt og kontroll over SaaS-apper (CASB), shadow IT	Defender for Cloud Apps
Sikkerhetsstatus på tvers av skyer, Secure Score (CSPM)	Defender for Cloud
Flom-angrep på lag 3 og 4	Azure DDoS Protection
SQL injection, XSS, HTTP flood (lag 7)	WAF
Stateful brannmur, FQDN-filtrering, threat intelligence	Azure Firewall
Enkle tillat/blokker-regler per subnett eller NIC	NSG
RDP/SSH til VM uten offentlig IP	Azure Bastion
Lagre hemmeligheter, nøkler og sertifikater	Key Vault
Generativ AI-assistent for sikkerhetsteam	Security Copilot

Compliance (Purview m.fl.)

Hvis oppgaven sier…	Svar
Merke og kryptere dokumenter etter sensitivitet	Sensitivity labels
Hvor lenge data beholdes / når de slettes	Retention labels / Data Lifecycle Management
Hindre deling av kredittkortnummer o.l.	DLP
Risikofylt aktivitet fra ansatte (nedlasting før oppsigelse)	Insider Risk Management
Beskyttelse justeres automatisk etter brukerens risiko	Adaptive Protection
Samlet oversikt over datarisiko og oversharing	DSPM
Undersøke datainnbrudd med generativ AI	Data Security Investigations
Compliance score, assessments, improvement actions	Compliance Manager
Upassende kommunikasjon (trakassering, trusler)	Communication Compliance
Finne og bevare data til juridiske saker	eDiscovery
Hvem gjorde hva, og når (aktivitetslogg)	Audit
Kartlegge datakilder og samle metadata	Purview Data Map
Finne, forstå og styre data	Purview Unified Catalog
Microsofts revisjonsrapporter og sertifiseringer	Service Trust Portal

1. Grunnleggende konsepter

Domene 1 · 10–15 % av eksamen

Shared responsibility model

Ansvaret for sikkerhet deles mellom Microsoft og kunden. Jo mer mot SaaS, desto mer tar Microsoft.

Lag	On-premises	IaaS	PaaS	SaaS
Fysisk + host	Kunde	Microsoft	Microsoft	Microsoft
OS	Kunde	Kunde	Microsoft	Microsoft
Apper	Kunde	Kunde	Kunde	Microsoft
Data	Kunde	Kunde	Kunde	Kunde
Kontoer, tilgang, endepunkter	Kunde	Kunde	Kunde	Kunde

Eksempler: **IaaS** = Azure VM · **PaaS** = Azure App Service · **SaaS** = Microsoft 365.

> **HUSK** Uansett modell er kunden **ALLTID** ansvarlig for **data, endepunkter, kontoer og tilgangsstyring**.

Defense in depth

Flere lag med sikkerhet, slik at ett brutt lag ikke gir full tilgang.

#	Lag	Eksempler	Azure-tjeneste
1	Fysisk	Datasentre, låser, vakter	(Microsoft)
2	Identitet og tilgang	IAM, SSO, MFA, RBAC	Entra ID, Conditional Access
3	Perimeter	DDoS-beskyttelse, brannmurer	DDoS Protection, Azure Firewall
4	Nettverk	Segmentering	VNet, NSG
5	Compute	Patching, endpoint protection	Bastion
6	Applikasjon	Sikker kode	WAF
7	Data	Kryptering, klassifisering	Key Vault



CIA-triaden

Bokstav	Betyr	Rammes av
Confidentiality	Kun autoriserte har tilgang	Datalekkasje
Integrity	Data endres ikke uautorisert	Manipulering
Availability	Tilgjengelig når det trengs	DDoS-angrep

Zero Trust

Motto: «**Never trust, always verify**». Ingen implisitt tillit basert på nettverkslokasjon.

Prinsipp	Betyr
Verify explicitly	Verifiser alltid på alle datapunkter: identitet, lokasjon, enhet, tjeneste
Least privilege access	Minimum nødvendig tilgang (just-in-time / just-enough-access)
Assume breach	Anta at brudd skjer eller har skjedd. Segmenter, krypter, begrens skadeomfang (blast radius)

Seks pilarer: Identiteter · Enheter · Apper · Data · Infrastruktur · Nettverk.

Kryptering og hashing

Type	Nøkkel	Egenskap	Eksempel
Symmetrisk	Samme nøkkel til kryptering og dekryptering	Rask, men nøkkeldeling er en utfordring	AES
Asymmetrisk	Public/private nøkkelpar	Tregere, løser nøkkeldelingen	RSA
Hashing	Ingen (én-veis)	Verifiserer integritet, kan ikke reverseres	SHA-256

Tilstand	Betyr	Beskyttelse
At rest	Data lagret på disk	Kryptert på lagringsmediet
In transit	Data på vei over nettverk	TLS/SSL
In use	Data i minne/under behandling	Maskinvarebeskyttelse

GRC: governance, risk, compliance

Begrep	Betyr
Governance	Regler, policyer og prosesser for å styre IT og sikkerhet
Risk	Identifisere, vurdere og redusere trusler mot organisasjonen
Compliance	Oppfylle lovkrav og regelverk (GDPR, HIPAA, ISO 27001)

TILLEGG **Data residency** = hvor data fysisk lagres geografisk (f.eks. EU-regionen). **Data sovereignty** = data er underlagt lovene i landet der de ligger. Begge dukker ofte opp i compliance-spørsmål.

Identitetskonsepter

Authentication (AuthN)	Authorization (AuthZ)
Bevise **HVEM** du er. Passord, MFA, biometri, sertifikat	Bestemme **HVA** du får gjøre. RBAC, ACL, policyer
Skjer først	Skjer etter autentisering

Begrep	Betyr
Identity Provider (IdP)	Oppretter og administrerer identitetsinfo. Eks: Entra ID, Google, ADFS
Directory service	Lagrer og organiserer info om brukere og nettverksressurser
Active Directory (AD)	Microsofts on-prem katalog: brukere, maskiner, grupper i hierarki
Microsoft Entra ID	Skybasert katalog for Microsoft 365, Azure og SaaS-apper (tidligere Azure AD)
Federation	Tillit mellom identitetsleverandører. Brukere får tilgang på tvers av domener uten egen innlogging

HUSK **Identitet er den nye sikkerhetsgrensen** (perimeter) i en cloud-first verden, ikke nettverket.

2. Identitet i Microsoft Entra

Domene 2 · 25–30 % av eksamen

2.1 Entra og Entra ID

- **Microsoft Entra** = hele produktfamilien for identitet og tilgang.
- **Entra ID** = kjernen: Microsofts skybaserte IAM-tjeneste (het tidligere **Azure AD**). Samme tjeneste, nytt navn.
- Lagrer identiteter (brukere, grupper, enheter, apper), autentiserer, styrer tilgang og gir **SSO**.
- **Tenant** = organisasjonens egen instans av Entra ID.

ANALOGI Hotellresepsjonen. Har gjestelisten, sjekker ID og gir nøkkelkort.

Funksjon	Hva den gjør
Authentication	Verifiserer identitet før tilgang
Single sign-on (SSO)	Én innlogging til mange apper
App management	Integrere og styre SaaS- og bedriftsapper
Device management	Registrere og styre enheter, håndheve policyer
B2B collaboration	Eksterne partnere får tilgang til dine ressurser
Kundeinnlogging (CIAM)	Kunder logger inn i dine apper (se External ID)

Lisenser

Lisens	Gir blant annet
Free	Grunnleggende
P1	**Conditional Access**
P2	**Identity Protection** og **PIM**
ID Governance	Lifecycle workflows, entitlement management, access reviews (deler også i P2)

PASS OPP Lisenskrav endrer seg. Sjekk Learn før eksamen.

2.2 Identitetstyper

Type	Hva	Eksempel
Bruker	Person (ansatt eller gjest)	Chris i Entra
Enhet	PC eller telefon	Registrert / joinet PC
Gruppe	Samling identiteter, gir tilgang til mange samtidig	«Økonomi»
Workload	Apper og tjenester	Service principal, managed identity
Agent	AI-agent	Agent i Copilot Studio

- **Service principal** = identitet for en app.
- **Managed identity** = Azure-ressurs får identitet automatisk, uten at du lagrer passord i koden.
- **Enhetsidentiteter:** *registered* (privat enhet) · *joined* (organisasjonens enhet) · *hybrid joined* (on-prem + Entra).

2.3 Hybrid identitet

```
On-prem AD DS ──[ Entra Connect ]──► Entra ID ──► Microsoft 365, Azure, skyapper
(Kerberos / LDAP)   synkroniserer     (OAuth / SAML)
```

- **Entra Connect** (tidligere Azure AD Connect) synkroniserer identiteter fra AD DS til Entra ID.
- Brukeren har **én identitet**, samme brukernavn/passord og SSO til både sky og on-prem.
- Administreres ett sted, endringer synkroniseres automatisk.
- Vanlig i norske bedrifter fordi gamle servere og apper trenger AD DS (Kerberos, LDAP, Group Policy).

PASS OPP **AD DS ≠ Entra ID.** AD DS = on-prem, Kerberos/LDAP. Entra ID = sky, OAuth/SAML.

2.4 External ID (eksterne identiteter)

Konfigurasjon	For hvem	Hvordan
Workforce tenant: B2B collaboration	Partnere og gjester som samarbeider med dine ansatte	Gjest legges inn som gjestebruker i din tenant (Teams, apper)
External tenant (CIAM)	Forbrukere og kunder som bruker dine egne apper	Egen, separat tenant med kundekontoer, registrering og innlogging

HUSK **B2B** = samarbeide med andre organisasjoner. **Kundeløsning** = la kunder logge inn i appen din.

PASS OPP **Azure AD B2C** er ikke tilgjengelig for nye kunder (fra 1. mai 2025). Nye kundeløsninger bruker External ID. Eldre materiell (inkl. studieguiden) bruker fortsatt «B2C».

2.5 Autentiseringsmetoder og MFA

Passord < Passord + MFA < Passordløst (svakest → sterkest).

Metode	Nivå	Merknad
Passord	Lavest	Noe du vet. Kan gjettes, stjeles, fiskes ut
SMS / talesamtale	Middels	Engangskode. Fungerer, men svakere og ikke passordløst
OATH-token	Middels	Maskin-/programvaretoken med tidsbaserte koder (TOTP)
Sertifikatbasert (CBA)	Høy	Smartkort / X.509. Phishing-resistent
Microsoft Authenticator	Høyest	Godkjenn på mobilen. Passordløst
Windows Hello for Business	Høyest	Biometri eller PIN knyttet til enheten. Passordløst
FIDO2-sikkerhetsnøkkel / passkey	Høyest	Fysisk nøkkel. Passordløst

MFA-faktor	Type	Eksempler
Noe du **vet**	Kunnskap	Passord, PIN, sikkerhetsspørsmål
Noe du **har**	Besittelse	Telefon, maskinvaretoken, smartkort
Noe du **er**	Biometri	Fingeravtrykk, ansiktsgjenkjenning, iris

- **Phishing-resistente metoder:** Windows Hello · FIDO2 · passkey (Authenticator) · CBA.
- **Passordløst er sterkest** fordi det ikke finnes noe passord å stjele eller fiske ut.
- **Temporary Access Pass (TAP):** midlertidig kode for å sette opp passordløse metoder.
- Selv om passordet stjeles kommer ikke angriperen inn uten andre faktor.

Forkortelse	Betyr
SSPR	Self-Service Password Reset
OATH	Open Authentication
TOTP / OTP	Time-based One-Time Password / One-Time Passcode
FIDO	Fast Identity Online

2.6 Passordadministrasjon

Funksjon	Hva
Password protection	Blokkerer svake/vanlige passord globalt. Støtter egne forbudte ord
SSPR	Brukeren nullstiller selv: glemmer passord → bekrefter identitet (Authenticator/telefon) → nytt passord, uten helpdesk. Færre henvendelser til IT
Password hash sync	Synkroniserer passord-hasher til skyen for sømløs hybrid innlogging
Password writeback	Nytt passord skrives tilbake til on-prem AD

PASS OPP SSPR i **hybrid** krever **password writeback**. Krever premium-lisens.

2.7 Conditional Access (CA)

KORT SAGT Regler av typen «hvis X, så Y». Entras policy-motor for Zero Trust («verify explicitly» i praksis).

Prinsipp: **Signals → Decisions → Enforcement**.

Signaler (HVIS)	Krav / kontroller (SÅ)
Bruker eller gruppe	Tillat tilgang
IP-sted / named location	Blokker tilgang
Enhetens tilstand (compliant)	Krev MFA
Appen som åpnes	Krev compliant eller hybrid-joinet enhet
Innloggingsrisiko (fra Identity Protection)	Krev godkjent klientapp · krev passordbytte · vilkår for bruk
Skyapp eller handling	Sesjonskontroll: begrenset tilgang, hvor ofte du må logge inn på nytt

Eksempler: krev MFA for alle administratorer · blokker innlogging fra land dere ikke har ansatte i · krev compliant enhet for SharePoint.

ANALOGI Vakten ved inngangen: ser på hvem du er, hvor du kommer fra og hva du har med deg, og bestemmer om du slipper inn, må bekrefte mer eller blir avvist.

HUSK Krever **Entra ID P1**. **Report-only**-modus tester uten å håndheve (så du ikke låser deg ute). **Security defaults** er gratis og enklere, men mindre fleksibelt. Du bruker **enten** security defaults **eller** CA, ikke begge.

2.8 Global Secure Access (SSE)

Sikker nettverkstilgang **uten tradisjonell VPN**, bygget på Zero Trust (Security Service Edge).

Del	Hva den gjør
Entra Internet Access	Sikrer internett og SaaS (f.eks. Microsoft 365), webfiltrering
Entra Private Access	Tilgang til interne apper (on-prem eller sky) uten VPN, bare de appene brukeren skal ha

ANALOGI I stedet for å åpne hele kontoret for alle (VPN) får hver person en privat korridor til akkurat de rommene de skal til.

Kombineres med Conditional Access, så nettverkstilgang styres av identitet, enhet og risiko.

2.9 Roller og RBAC

Hvem (bruker/gruppe) + **Rolle** (hva) + **Omfang/scope** (hvor) = **Tilgang**. Prinsipp: least privilege.

Begrep	Betyr
Rolledefinisjon	Samling tillatelser, f.eks. «kan nullstille passord»
Rolletildeling	Kobler rolle til bruker/gruppe
Scope	Hvor rollen gjelder (hele tenanten, administrativ enhet …)

Entra-rolle	Kan
Global Administrator	Alt i tenanten
User Administrator	Administrere brukere og grupper
Helpdesk Administrator	Nullstille passord for ikke-privilegerte brukere
Security Administrator	Administrere sikkerhet
Security Reader	Lese sikkerhetsinfo, ikke endre
Billing Administrator	Abonnementer og fakturering

	Styrer	Eksempler
Entra-roller	Entra-ressurser (brukere, grupper, innstillinger)	Global Administrator, User Administrator
Azure RBAC	Azure-ressurser (VM-er, lagring)	Owner (alt), Contributor (opprette/styre, ikke gi tilgang), Reader (se), User Access Administrator (styre tilgang)

- Innebygde og egendefinerte (custom) roller finnes.
- **Begrens antall Global Administrators.** Kombiner med PIM.

2.10 Entra ID Governance

KORT SAGT Riktige personer, riktig tilgang, riktig tid, og tilgangen fjernes når den ikke trengs.

Funksjon	Hva den gjør
Lifecycle workflows	Joiner / mover / leaver: automatisk tilgang når noen begynner, endring ved ny rolle, deaktivering når noen slutter
Entitlement management	*Access packages* (apper, grupper, nettsteder). Brukere ber om pakken, godkjenning og utløp håndteres automatisk
Access reviews	Jevnlig «skal de fortsatt ha denne tilgangen?» Reviewer: eier, leder eller brukeren selv. Kan fjerne tilgang automatisk
Terms of use	Brukere må godta vilkår før tilgang
PIM	Se under

```
Ansatt begynner  ->  Lifecycle workflow gir tilgang
Ber om tilgang   ->  Entitlement management (access package, godkjenning)
Tid går          ->  Access reviews rydder bort unødvendig tilgang
Ansatt slutter   ->  Lifecycle workflow fjerner tilgang
```

2.11 Privileged Identity Management (PIM)

Ingen har stående admin-rettigheter. Du **aktiverer** rollen ved behov, tidsbegrenset (**just-in-time**).

```
Eligible ──[ aktiver: MFA + begrunnelse + evt. godkjenning ]──► Active ──[ tid går ut ]──► Eligible
```

Begrep	Betyr
Eligible	Kan aktivere rollen, men har den ikke nå
Active	Rollen er aktiv akkurat nå (tidsbegrenset)

- Varsler ved aktivering, full revisjonslogg, access reviews av privilegerte roller.
- Gjelder Entra-roller, Azure-ressursroller og gruppemedlemskap.

ANALOGI Du har ikke hovednøkkelen i lommen hele dagen. Du henter den i resepsjonen og leverer den tilbake etterpå.

HUSK PIM = **just-in-time + least privilege**. Krever Entra ID **P2** eller Governance.

2.12 Entra ID Protection

Bruker maskinlæring til å oppdage identitetsrisiko og kan svare automatisk.

Risikotype	Betyr	Typisk respons
User risk	Kontoen er sannsynligvis kompromittert	Krev passordendring eller blokker
Sign-in risk	Innloggingen er sannsynligvis ikke gjort av eieren	Krev MFA eller blokker

- **Deteksjoner:** lekkede påloggingsdata, anonym IP (Tor), umulig reise, password spray, uvanlige påloggingsegenskaper.
- **Risikonivå:** low / medium / high. **Rapporter:** risky users, risky sign-ins, risk detections.

ANALOGI Banken som stopper kortet ditt når det brukes i et annet land fem minutter etter en handel hjemme.

HUSK Identity Protection **oppdager**. Conditional Access **håndhever**. Krever **P2**.

2.13 Entra Verified ID

Digitale, verifiserbare legitimasjoner du **eier selv** og viser frem uten å dele mer enn nødvendig. Bygger på åpne standarder og desentraliserte identifikatorer (DID).

```
Issuer ──gir──► Holder (digital lommebok, f.eks. Authenticator) ──viser──► Verifier
```

- **Bruk:** fjern-onboarding av ansatte, bevise utdanning/arbeidsforhold, kontoopprettelse og passordnullstilling uten helpdesk.

ANALOGI Førerkortet i lommeboka. Den som sjekker kan stole på at det er ekte uten å ringe utstederen.

2.14 Entra Agent ID

AI-agenter handler selvstendig og passer verken som brukere eller vanlige apper. De får en **egen identitet** (en spesiell type service principal).

- Least privilege, og hindres fra de mest kritiske rollene.
- Samme beskyttelser som brukere: Conditional Access og Identity Protection for agenter, livssyklus og logging.
- Motvirker **agent sprawl** (agenter uten oversikt og styring). Lages fra en *agent identity blueprint* (mal).
- Ingen passord eller MFA: bruker **federated identity credentials**.

PASS OPP Status (preview/lansert) kan ha endret seg. Sjekk Learn.

3. Microsofts sikkerhetsløsninger

Domene 3 · 35–40 % av eksamen · **tyngst, legg mest tid her**

3.1 Defender-familien på et blikk

Tjeneste	Beskytter	Nøkkelord
Defender for Endpoint	PC-er, servere (Windows, macOS, Linux)	EDR, skadevare, ransomware, isolere enhet, sårbarhetsstyring
Defender for Office 365	E-post, Teams, SharePoint, OneDrive	Phishing, Safe Attachments, Safe Links, anti-spam/malware
Defender for Identity	On-prem Active Directory	Stjålne legitimasjoner, lateral movement, domain dominance
Defender for Cloud Apps	SaaS og skyapper	CASB, shadow IT-oppdagelse, risikabel appbruk
Defender for Cloud	Azure, hybrid, multicloud	CSPM, CWP, Secure Score
Defender XDR	Samler alt over	Korrelasjon, incidents, én portal

HUSK **Endpoint** = enheter · **Office 365** = e-post · **Identity** = kontoer/AD · **Cloud Apps** = SaaS.

TILLEGG Studieguiden nevner også **Defender Vulnerability Management** (kontinuerlig oppdagelse, risikobasert prioritering, utbedringssporing) og **Defender Threat Intelligence** (trusselaktørprofiler, IOC-er, TTP-er). Kjenn navnene og én setning hver.

3.2 Microsoft Defender XDR

XDR = Extended Detection and Response. Kobler sammen sikkerhetsdata fra identiteter, enheter, e-post og apper for å oppdage, undersøke og håndtere avanserte angrep.

```
1. Phishing          ->  Defender for Office 365 oppdager e-posten
2. Kapret konto      ->  Defender for Identity ser mistenkelig identitetsaktivitet
3. Skadevare         ->  Defender for Endpoint ser mistenkelig aktivitet på PC-en
4. Korrelasjon       ->  Defender XDR kobler varslene til ÉN incident
5. Respons           ->  Sikkerhetsteamet undersøker og utfører tiltak
```

Begrep	Betyr
Alert (varsel)	Signal om mulig mistenkelig eller skadelig aktivitet
Incident	Samling relaterte varsler og bevis som representerer et mulig angrep
Correlation	Koble sammen relaterte varsler og aktiviteter
Triage	Vurdere, sortere og prioritere varsler etter alvorlighetsgrad
Automated investigation and response	Automatisk undersøkelse og støttede utbedringstiltak
Remediation	Fjerne trusselen eller redusere skaden (f.eks. isolere enhet)

Defender-portalen (security.microsoft.com) er ett sentralt sted: Incidents & alerts · Assets · Investigation · Response actions · Reports and hunting. Hva som er tilgjengelig avhenger av lisens, konfigurasjon og rettigheter.

EKSAMEN Koble sammen varsler fra e-post, identitet og enheter for å oppdage et avansert angrep? → **Defender XDR**.

Detaljer per tjeneste

- **Endpoint:** oppdager skadevare/ransomware, undersøker angrep, kan **isolere** kompromitterte enheter, automatisk undersøkelse og utbedring.
- **Office 365:** oppdager phishing, beskytter mot ondsinnede lenker og vedlegg, undersøker e-postbaserte angrep.
- **Identity:** mistenkelig autentisering, stjålne legitimasjonsopplysninger, lateral movement.
- **Cloud Apps (CASB):** shadow IT-oppdagelse, appaksesskontroll, databeskyttelse, anomalideteksjon.

3.3 Defender XDR vs. Microsoft Sentinel

	Defender XDR	Microsoft Sentinel
Type	XDR: integrert trusselbeskyttelse	Skybasert **SIEM + SOAR**
Fokus	Angrep på tvers av Microsofts sikkerhetstjenester	Bred overvåking, logger fra mange ulike kilder
Gjør	Varsler → incidents, undersøkelse og respons	Samler og analyserer data, AI/analytics, automatisering

	Betyr	Gjør
SIEM	Security Information and Event Management	Samler, lagrer og analyserer logger og hendelser for å oppdage trusler
SOAR	Security Orchestration, Automation and Response	Automatiserer og koordinerer respons (playbooks)

Sentinel-begreper

Begrep	Hva
Analytics rules	Betingelser som automatisk lager alerts/incidents når de treffer
Machine learning	Oppdager avvikende atferd uten eksplisitte regler
Threat intelligence	Kjente ondsinnede aktører og IOC-er som beriker deteksjon
Hunting queries	Proaktiv trusseljakt med **KQL** (Kusto Query Language)
Playbooks	Automatiserte responsarbeidsflyter bygget på **Azure Logic Apps**
Investigation graph	Visualiserer angrepets tidslinje og entitetsrelasjoner
Data connectors	Kobler inn datakilder (Microsoft-tjenester, brannmurer, tredjepart)
Workbooks	Dashboards for visualisering av data

TILLEGG **Data connectors** og **workbooks** sto ikke i kildene dine, men er standard Sentinel-begreper på eksamen.

PASS OPP Sentinel er svært relevant for SOC-roller. Verdt å kunne forklare godt i intervju (se kapittel 8 for hands-on-tips).

3.4 Security Copilot

Generativ AI-assistent for sikkerhet. Du skriver på vanlig språk, og den hjelper deg å undersøke trusler, oppsummere hendelser og svare raskere.

ANALOGI En erfaren kollega i vaktrommet som allerede har lest loggene.

Bruk: oppsummere incidents og foreslå neste steg · undersøke varsler og risikable brukere · analysere skript og filer · lage og forklare KQL · hjelpe med policyer i Entra, Intune og Purview. I Entra kan den forklare hvorfor en bruker ble flagget.

HUSK Copilot **erstatter ikke** analytikeren. Den sparer tid, mennesket tar beslutningen og kontrollerer svaret. Svar kan være feil: dobbeltsjekk og bruk tommel opp/ned.

Begrep	Betyr
Prompt	Spørsmålet eller instruksjonen
Session	En samtale med historikk
Plugin	Kobling til datakilder (Defender, Sentinel, Entra, Intune, Purview, tredjepart)
Promptbook	Ferdig serie prompts for en vanlig oppgave (triage, jakt, rapportering)
Agent	Selvstendig AI-løsning for en gjentakende oppgave
SCU	Security Compute Unit: enhet for kapasitet og forbruk
Standalone	Eget portalområde (securitycopilot.microsoft.com)
Embedded	Copilot bygd inn i Defender, Entra, Intune, Purview
Workspace	Der kapasitet, plugins og roller konfigureres

Slik behandles en prompt

```
Prompt -> Pre-processing (grounding) -> Orkestrering (velger plugins, henter data)
       -> LLM lager svar -> Post-processing (kontroll, formatering) -> Svar med kilder
```

- Copilot bruker data **du** har tilgang til. Rettighetene dine bestemmer hva den kan hente.
- **Grounding:** svar bygger på dine egne data, ikke bare modellens generelle kunnskap.
- Kundens data brukes **ikke** til å trene de grunnleggende modellene og blir i organisasjonens tenant.

Effektiv prompt = Goal + Context + Expectations + Source

Element	Spørsmål	Eksempel
Goal	Hva vil du vite/gjøre?	Oppsummer risikable innlogginger for bruker X siste 24 timer
Context	Hvorfor, hvem er du?	Jeg er SOC-analytiker og undersøker mistenkelig innlogging
Expectations	Hvordan vil du ha svaret?	Kort punktliste med anbefalt neste steg
Source	Hvor skal data hentes fra?	Bruk Entra-data

Tips: vær spesifikk · bygg på forrige svar i samme session · bruk promptbooks for gjentakende oppgaver.

Aktivering: (1) Azure-abonnement · (2) opprett kapasitet (abonnement, ressursgruppe, navn, region, antall SCU-er) · (3) Global Administrator eller Security Administrator fullfører onboarding · (4) velg hvem som får bruke den, slå på plugins, sett datadeling · (5) bruk standalone-portalen eller embedded. Kapasitet faktureres per time. Sjekk gjeldende lisensvilkår (E5-kunder har hatt kapasitet inkludert).

3.5 Intune

Microsofts **enhetsadministrasjon**. Setter compliance-regler for enheter, som Conditional Access kan kreve (f.eks. «krev compliant enhet»).

3.6 Azure-nettverkssikkerhet: oversikt

Tjeneste	Lag (defense in depth)	Én setning
DDoS Protection	Perimeter	Stopper flom-angrep
Azure Firewall	Perimeter	Administrert, stateful brannmur for hele nettverket
WAF	Applikasjon	Beskytter webapper mot kjente angrep
Virtual Network	Nettverk	Isolerer og segmenterer ressurser
NSG	Nettverk	Filtrerer trafikk med regler på subnett og NIC
Bastion	Compute	Sikker RDP/SSH uten offentlig IP
Key Vault	Data	Trygg lagring av hemmeligheter, nøkler, sertifikater

Tjeneste	OSI-lag	Beskytter
DDoS Protection	3 og 4	Mot flom-angrep på nettverk og transport
NSG	3 og 4	Enkle regler per subnett eller NIC
Azure Firewall	3 til 7	All trafikk inn og ut
WAF	7	Webapper: SQL injection, XSS, HTTP floods

3.7 Azure DDoS Protection

DDoS overbelaster applikasjoner og servere så de blir trege eller slutter å svare. Rammer offentlige endepunkter og **availability** i CIA.

> **ANALOGI** Tusenvis av falske kunder stimler inn i restauranten så ekte gjester ikke kommer inn.

Angrepstype	Hva det gjør	Lag
Volumetric	Oversvømmer nettverket så båndbredden går tom	Nettverk
Protocol	Tømmer serverressurser via svakheter i protokoller	3 og 4
Resource / application layer	Angriper webapplikasjoner	7

- Analyserer trafikk og kaster det som ser ut som DDoS. Beskytter **lag 3 og 4**. Lag 7 krever **WAF** i tillegg.

- Azure har infrastrukturbeskyttelse som standard, men terskelen er høy, den gir ingen telemetri/varsling, og trafikk plattformen ser som ufarlig kan likevel ødelegge appen din.

Fordel	Betyr
Always-on-overvåking	24/7. Angrep avverges automatisk. Varsel via Azure Monitor
Adaptiv tuning	Lærer appens trafikkprofil over tid
Analyse, metrikker, varsling	Telemetri via Azure Monitor. Logger kan til Event Hubs, Monitor-logger, Storage
Attack analytics	Rapporter hvert 5. minutt under angrep. Logger kan til Sentinel/SIEM

	DDoS Network Protection	DDoS IP Protection
Modell	Beskytter ressurser i et virtuelt nettverk	Betaler per beskyttet IP
DDoS rapid response	Ja	Nei
Cost protection	Ja	Nei
WAF-rabatt	Ja	Nei

HUSK **DDoS rapid response (DRR)**: kun Network Protection. Tilgang til DRR-teamet under pågående angrep. **Beste praksis:** kombiner DDoS (lag 3/4) og WAF (lag 7) · design for redundans · slå på telemetri og varsling · ha en responsplan.

3.8 Azure Firewall

Administrert, skybasert, **stateful** nettverkssikkerhetstjeneste.

ANALOGI Vakten ved hovedinngangen med regelliste, som husker hvem som allerede er sluppet inn.

Funksjon	Betyr
Stateful	Holder styr på aktive tilkoblinger
Innebygd HA + availability zones	Kjører videre ved feil og høy last
Nettverks- og applikasjonsfiltrering	IP, port, protokoll og HTTP/S via **FQDN**, inn og ut
NAT	SNAT og DNAT
Threat intelligence	Varsler/blokkerer kjente ondsinnede IP-er og domener
Logging	Azure Monitor, Log Analytics, Event Hubs

NAT	Gjør	Retning
SNAT (source)	Privat IP → offentlig Azure-IP	Ut fra VNet til internett
DNAT (destination)	Offentlig IP → privat IP	Inn fra internett til private ressurser

Nivå	For hvem	Kjernen
Basic	Små og mellomstore bedrifter	Grunnleggende. Threat intelligence kun alert. Ca. 250 Mbps
Standard	De fleste produksjonsmiljøer	Lag 3–7-filtrering og threat intelligence som varsler og blokkerer
Premium	Sensitive og regulerte miljøer	Standard + **IDPS** (over 67 000 signaturer i 50+ kategorier) og TLS-inspeksjon

IDPS finner kjente mønstre i trafikken (bytesekvenser malware bruker). **Azure Firewall Manager**: ett sted å styre flere brannmurer på tvers av abonnementer og regioner via brannmurpolicyer (vanlige VNet og Virtual WAN / Secure Virtual Hub).

	Azure Firewall	NSG	WAF
Hva	Sentral, administrert, stateful	Enkle regler per subnett/NIC	Beskytter webapper
Filtrerer på FQDN	Ja	Nei	Nei
Threat intelligence	Ja	Nei	Nei

3.9 Web Application Firewall (WAF)

Sentralisert beskyttelse av webapper mot vanlige angrep. Du patcher en sårbarhet **ett sted** i stedet for i hver app. Bygger på **OWASP core rule set**.

Angrep	Hva det gjør	Rammer
SQL injection	Ondsinnet SQL i inputfelt	Databasen
Cross-site scripting (XSS)	Skript i nettsider andre ser, stjeler sesjonstokens	Andre brukeres nettleser
HTTP flood	Mange HTTP-forespørsler overbelaster appen (lag 7)	Availability
Remote file inclusion	Lurer appen til å kjøre ekstern fil	Serveren

Distribusjon	Beskyttelse
Application Gateway	**Regional** WAF for apper i én region
Application Gateway for Containers	Containerbaserte arbeidsbelastninger
Front Door	**Global** WAF. Blokkerer nær kilden
Azure CDN	Statisk og dynamisk CDN-innhold

HUSK **Regional = Application Gateway. Global = Front Door.** WAF dekker lag 7-DDoS (HTTP floods), DDoS Protection dekker lag 3/4. Sammen = defense in depth. WAF-hendelser kan undersøkes med Security Copilot (Azure WAF-plugin må være på).

3.10 Segmentering, VNet, subnett og peering

Segmentering = dele nettverket i mindre biter. Tre grunner: gruppere, isolere, styringspolicyer. Støtter Zero Trust **(assume breach)**: ett kompromittert segment kan begrenses og lateral bevegelse hindres. Hver grense er en mulighet til å inspisere og filtrere.

```
Uten segmentering:  [ web + app + db + HR ]            <- ett brudd = alt er åpent
Med segmentering:   [ web ] | [ app ] | [ db ] | [ HR ]  <- brudd stoppes ved grensen
```

ANALOGI HR, salg og kundeservice har hvert sitt kontor.

Azure Virtual Network (VNet) er byggeklossen for private nettverk i Azure. **Ingen trafikk er tillatt mellom VNet, eller inn til VNet, som standard.** Kommunikasjon må settes opp eksplisitt.

VNet-funksjon	Betyr
Internett	Ut som standard. Inn styres via offentlige IP-er eller lastbalansere
Mellom Azure-ressurser	Trygt innen VNet, ikke over offentlig internett
On-prem	Site-to-site VPN, point-to-site VPN eller ExpressRoute
Filtrering	NSG og Azure Firewall
Ruting	Automatisk mellom subnett. Egne regler mulig

- **Site-to-site:** hele kontornettverket til Azure. **Point-to-site:** én enhet til Azure. **ExpressRoute:** privat, dedikert forbindelse (ikke over offentlig internett).
- **Subnett:** mindre segmenter i et VNet, hvert med egne kontroller (web i ett, database i et annet).
- **VNet peering:** kobler to VNet så de snakker som ett. Går over Azures stamnett, ikke internett. Fungerer på tvers av regioner (*global VNet peering*). Analogi: privat gangbro mellom to bygninger.

3.11 Network Security Groups (NSG)

Filtrerer trafikk til og fra Azure-ressurser i et VNet via regler. Én NSG per subnett og per NIC. Samme NSG kan knyttes til mange. Regler evalueres etter prioritet ut fra **5-tuple**: kilde · kildeport · mål · målport · protokoll. Resultat: Allow eller Deny.

Egenskap	Betyr
Name	Unikt navn
Priority	**Lavest tall evalueres først. Første treff vinner**

Egenskap	Betyr
Source / destination	IP, IP-område, service tag eller ASG
Protocol	TCP, UDP, ICMP, Any
Direction	Inbound / outbound
Port range	Enkeltport eller område
Action	Allow / Deny

Service tag = gruppe IP-prefikser fra en bestemt Azure-tjeneste. **Standardregler** kan ikke fjernes, men kan overstyres med lavere tall:

Retning	Regel	Gjør
Inn	AllowVNetInBound	Tillater VNet til VNet (behandles først)
Inn	AllowAzureLoadBalancerInBound	Tillater fra lastbalanserer (nummer to)
Inn	DenyAllInBound	Blokkerer alt annet inn (sist)
Ut	AllowVNetOutBound	Tillater ut til andre ressurser i VNet
Ut	AllowInternetOutBound	Tillater ut til internett
Ut	DenyAllOutBound	Blokkerer alt annet ut

Application security groups (ASG): grupper VM-er (WebServers, AppServers, DbServers) og bruk gruppene som kilde/mål i NSG-regler i stedet for enkelt-IP-er. Nye VM-er i gruppen får reglene automatisk. Analogi: «alle i økonomiavdelingen» i stedet for hvert navn.

NSG vs. Azure Firewall: NSG = distribuert filtrering per subnett/NIC. Azure Firewall = sentralt, fullt stateful, på tvers av abonnementer og VNet. De **utfyller** hverandre.

3.12 Azure Bastion

Problem: eksterne utviklere trenger RDP/SSH mot VM-er. Å åpne portene mot internett gir stor angrepsflate.
Løsning: Bastion, en fullt administrert PaaS-tjeneste i VNet-et ditt.

> **ANALOGI** Alle går gjennom én sikker inngang med vakt, ikke en åpen bakdør.

- RDP/SSH fra Azure-portalen (nettleser, HTML5) over **TLS, port 443**. Passerer bedriftsbrannmurer.
- VM-ene trenger **ingen offentlig IP**, agent eller klientprogramvare. Bastion kobler til VM-ens private IP.
- Gir tilgang til alle VM-er i VNet og peered VNet. Distribueres per VNet.
- Beskytter mot portskanning. Herdet og oppdatert av plattformen (beskytter mot zero-day).

Nivå	Kjernen
Developer	Gratis, delt infrastruktur, dev/test. Én tilkobling om gangen
Basic	Dedikert, fast kapasitet, produksjon
Standard	Basic + skalering, delbare lenker, IP-baserte tilkoblinger, native klient, filoverføring
Premium	Standard + sesjonsopptak og kun privat distribusjon

Tilkobling: nettleser (alle nivåer) · native klient (Standard+) · delbare lenker (Standard+).

3.13 Azure Key Vault

Skytjeneste for trygg lagring av **hemmeligheter, nøkler og sertifikater** i en sentral, revidert tjeneste.

> **ANALOGI** Bankhvelv med logg på alle besøk.

Område	Betyr
Secrets management	Tokens, passord, API-nøkler, tilkoblingsstrenger
Key management	Lage og styre krypteringsnøkler
Certificate management	Opprette, administrere, distribuere TLS/SSL-sertifikater (livssyklus, automatisk fornyelse)

- Utviklere slipper å lagre hemmeligheter i koden. Appen henter dem ved kjøring.
- **AuthN** = Entra ID. **AuthZ** = Azure RBAC eller Key Vault access policy. All bruk logges.

- Microsoft ser ikke eller henter ut dataene dine. Støtter least privilege og begrenser blast radius.
- Replikeres innen region og til sekundær region. Integrerer med Azure Disk Encryption, Azure SQL, App Service.

Nivå	Beskyttelse	Passer for
Standard	Programvarebasert nøkkelbeskyttelse	De fleste
Premium	**HSM-beskyttede** nøkler	Strenge krav (finans, offentlig sektor)

HSM = dedikert maskinvare som lager og lagrer nøkler manipulasjonssikkert. Nøklene forlater aldri HSM-grensen.

3.14 Microsoft Defender for Cloud

CNAPP (Cloud-Native Application Protection Platform): samlet løsning for å beskytte applikasjoner gjennom hele livssyklusen, på tvers av **Azure, AWS, GCP og on-prem**.

> **ANALOGI** Sikkerhetssjefen for hele bygget: sjekker låsene (posture), vakter ved viktige rom (workload protection), tegningene før noe bygges (DevOps), og egne regler for robotene (AI).

Tre pilarer: DevOps-sikkerhet · **CSPM** (styre sikkerhetsstatus) · **CWP** (beskytte arbeidsbelastninger). Pluss AI-sikkerhet.

Begrep	Betyr
Sikkerhetspolicy	Regel som måler om en ressurs er trygt konfigurert (bygger på Azure Policy)
Sikkerhetsstandard	Samling policyer (initiative). Standard: **Microsoft Cloud Security Benchmark (MCSB)**. Kan legge til ISO 27001, PCI DSS
Anbefaling	Konkret tiltak, f.eks. «Slå på MFA»
Secure Score	Prosentscore. Flere gjennomførte anbefalinger = høyere score
Regulatory compliance dashboard	Hvor godt du følger valgte regelverk

Foundational CSPM (gratis)	Defender CSPM (betalt)
Secure score, anbefalinger, compliance, anbefalinger for Azure DevOps	**Attack path analysis**, **cloud security explorer**, agentløs skanning, AI-sikkerhet, code-to-cloud, pull request annotations

Attack path analysis: hvordan en angriper kan komme fra inngangspunkt til verdifulle ressurser. **Cloud security explorer:** kart/spørringer for å finne risiko.

CWP: Defender-planer (betalt, slås på per abonnement under Environment settings → Defender plans)

Plan	Beskytter
Servers	Virtuelle og fysiske servere (sårbarhetsvurdering)
Databases / SQL	Databaser (sårbarhet + trusseldeteksjon)
Storage	Lagringskontoer (malware-skanning, trusseldeteksjon)
Key Vault	Nøkkelhvelv
Containers	Kubernetes og containere (image-skanning, runtime-beskyttelse)
App Service	Webapper
APIs	API-er
AI Services	Generativ AI (prompt injection, jailbreak)

> **HUSK** **CSPM = forebygge** (finne svakheter). **CWP = oppdage og stoppe angrep** på selve arbeidsbelastningen.

- **DevOps-sikkerhet:** støtter GitHub, Azure DevOps og GitLab. Finner IaC-feilkonfigurasjoner (f.eks. åpen lagringskonto i en mal) og eksponerte hemmeligheter i kode. Analogi: sjekke byggetegningene før huset bygges.
- **AI-sikkerhet:** *AI SPM* (oversikt over AI BOM og sikkerhetsstatus, del av Defender CSPM) og *AI threat protection* (Defender for AI Services, trusler i sanntid).

4. Microsofts compliance-løsninger

Domene 4 · 20–25 % av eksamen

4.1 Service Trust Portal og personvern

- **Service Trust Portal (STP)**: servicetrust.microsoft.com. Offentlig side med dokumentasjon om Microsofts sikkerhet, personvern og samsvar: revisjonsrapporter (SOC, ISO, FedRAMP), sertifiseringer (f.eks. ISO 27001), compliance-guider og hvordan Microsoft beskytter kundedata.
- **Microsoft Priva**: håndtering av personvernrisiko. Identifiserer risiko, automatiserer GDPR-forespørsler (Subject Rights Requests), dataminimering og personvernvurderinger.

> **EKSAMEN** STP brukes til å **kontrollere Microsofts** sikkerhet og samsvar. Det er **ikke** et verktøy for trusseldeteksjon.

Microsofts seks personvernprinsipper

Prinsipp	Betyr
Control	Du har kontroll over egne data
Transparency	Åpenhet om hvordan data samles inn og brukes
Security	Data beskyttes mot uautorisert tilgang
Strong legal protections	Juridisk beskyttelse av personopplysninger, respekt for lokale lover
No content-based targeting	Personlig innhold brukes ikke til målrettet annonsering
Benefits to you	Databruk skal gi brukerne fordeler

4.2 Microsoft Purview: portalen

Sentralt verktøy for governance, risiko og compliance (GRC).

Område i portalen	Innhold
Core	Audit, Settings
Risk & Compliance	Compliance Manager, eDiscovery, Communication Compliance
Data Governance	Data Lifecycle Management, Data Catalog
Data Security	DLP, Information Protection, Insider Risk Management

4.3 Information Protection

1. Dataklassifisering: finne sensitive data

Verktøy	Gjør	Detaljer
Sensitive information types (SIT)	Oppdager **mønstre** (kredittkort, bankkonto, personopplysninger)	Built-in · named entity (navn, adresser, medisinske begreper) · custom (nøkkelord, regex) · **EDM** (eksakte verdier fra database) · confidence level · proximity
Trainable classifiers	Klassifiserer etter hva innholdet **handler om** (AI/ML)	Pre-trained eller custom (positive og negative eksempler). Eks: kontrakter, CV-er, fakturaer, HR-dokumenter

2. Sensitivity labels: merke og beskytte

Eksempler: Public, General, Confidential, Highly Confidential. Brukes på dokumenter og e-post, manuelt eller automatisk. Egenskaper: **customizable · clear text** (i metadata) **· persistent** (følger dokumentet) **· kun én etikett om gangen** per element.

Kan gjøre	Betyr
Encryption	Kryptere og begrense hvem som kan åpne/endre
Content marking	Vannmerker, topptekst, bunntekst
Automatic labeling	Bruke/anbefale etikett basert på sensitiv info

Kan gjøre	Betyr
Protect containers	Kontrollere tilgang til Teams, SharePoint, M365-grupper
Classification only	Klassifisere uten ekstra beskyttelse

Scopes: Files & other data assets · Emails · Meetings · Groups & sites.

PASS OPP Etikett på et Teams/SharePoint-område beskytter **selve området**. Den merker ikke automatisk hvert dokument inni.

Sensitivity label policy publiserer etiketter til brukere/grupper. Admin kan: velge hvem som ser etikettene · sette standardetikett · kreve begrunnelse ved fjerning/nedgradering · kreve at brukeren alltid velger etikett (mandatory) · lenke til hjelpesider. **Copilot:** Microsoft 365 Copilot respekterer labels og tilgangsrettigheter. Svar kan arve den mest restriktive etiketten.

3. Explorers

Explorer	Viser
Content explorer	Hvilke sensitive data finnes og **hvor** de ligger
Activity explorer	Hva **brukere gjør** med data (endre etikett, kopiere til USB, skrive ut, DLP-treff)

HUSK SIT = oppdager mønstre · Trainable classifiers = gjenkjenner tema · Sensitivity labels = merker og beskytter · Retention labels = hvor lenge data beholdes.

4.4 Data Loss Prevention (DLP)

Oppdager, overvåker og **hindrer uønsket deling** av sensitiv informasjon (kredittkort, personnummer, bankinfo).

- **Hvor:** Exchange/Outlook, SharePoint, OneDrive, Teams, Word/Excel/PowerPoint, Windows og macOS (Endpoint DLP), enkelte tredjepartsapper.
- **Handlinger:** Warn (policy tip) · Block with override (blokker, men overstyr med begrunnelse) · Block · Quarantine · logging og varsler.
- **Lage policy:** velg Data → Locations → Conditions → Actions. Ferdige maler finnes.
- **Endpoint DLP:** overvåker kopiering til USB/nettverk, utskrift, åpning i uautoriserte apper. Vises i Activity explorer.
- **Teams og AI:** kan blokkere meldinger med sensitiv info og advare mot deling med tredjeparts AI-nettsteder. Security Copilot kan oppsummere DLP-varsler (Alert Triage Agent).

4.5 Insider Risk Management og Adaptive Protection

IRM oppdager, undersøker og håndterer risikofylt aktivitet fra personer **internt**: datalekkasje, tyveri av bedriftshemmeligheter/IP, svindel, nedlasting før oppsigelse, deling med uautoriserte AI-tjenester. Bruker signaler fra Microsoft 365 og HR-systemer.

```
Policies -> Alerts -> Triage -> Investigate -> Action
```

- **Insider Risk Analytics:** kartlegger mulige risikoer før policyer opprettes.
- **Funksjoner:** policies (maler/egendefinert) · alerts · cases · user activity · content explorer. Personvern er innebygd.
- **Kategorier (studieguiden):** data theft · data leaks · IP theft · security policy violations · offensive behaviour.

Adaptive Protection

Bruker ML og risikonivåer fra IRM til å **tilpasse beskyttelsen automatisk** etter brukerens risiko.

Nivå	Risiko	Typiske tiltak
Minor	Lav	Policy tips, påminnelser
Moderate	Middels	Strengere advarsler, krav om begrunnelse
Elevated	Høy	Blokkering av deling eller apptilgang

Nivåene oppdateres automatisk. Integrerer med **DLP** (justerer delingsregler), **Data Lifecycle Management** (kan bevare slettet innhold fra Elevated-brukere i **120 dager**) og **Conditional Access** (krev vilkår, begrens apper, blokker).

Typisk eksamensspørsmål	Svar
Automatisk tilpasse beskyttelse etter risiko	Adaptive Protection

Typisk eksamensspørsmål	Svar
Oppdage risikofylt intern aktivitet	Insider Risk Management
Hindre deling av sensitive data	DLP
Begrense apptilgang etter policy	Conditional Access

4.6 DSPM og Data Security Investigations

DSPM (Data Security Posture Management): samlet oversikt over datarisiko. Svarer på: *Hvilke data har vi? Hvor ligger de? Hvem har tilgang? Hvordan er de beskyttet?* Anbefaler tiltak (labels, DLP), kan fjerne offentlige delingslenker og redusere oversharing. Samler innsikt fra DLP, IRM og Information Protection. Dekker M365, Azure, Microsoft Fabric og tredjepart (GCP, Snowflake, Databricks). **Shadow data** = sensitive data utenfor kjente/administrerte plasseringer. Sider: Posture · Objectives · AI observability · Asset explorer · Reports.

Data Security Investigations (DSI): undersøker datainnbrudd og lekkasjer ved hjelp av generativ AI. *Vector search* (søker på mening), *categorization*, *examination* (f.eks. eksponerte passord). Integrerer med IRM, Defender XDR, DSPM og unified audit log. Soft purge = kan gjenopprettes · hard purge = permanent. Pay-as-you-go.

Verktøy	Gjør
DSI	Undersøker data og risiko
DSPM	Finner datasikkerhetsrisikoer
IRM	Oppdager risikofylt intern aktivitet
DLP	Hindrer uønsket deling

4.7 Compliance Manager

Vurderer og forbedrer etterlevelse av lover og standarder på tvers av skymiljøer. **Compliance score** (0–100 %) viser fremdrift.

Begrep	Betyr
Compliance score	Høyere = flere forbedringstiltak fullført. Består av *your points* og *Microsoft-managed points*
Controls	Krav fra lov/standard. Microsoft-managed · Customer-managed · Shared
Assessments	Samling kontroller for én standard (f.eks. ISO 27001, GDPR, HIPAA)
Regulations	Ferdige maler for å opprette assessments
Improvement actions	Konkrete tiltak. Kan tildeles og dokumenteres

4.8 Communication Compliance

Oppdager upassende eller regelstridig kommunikasjon (trakassering, truende språk, deling av sensitiv info) i Teams, Outlook, Viva Engage, WhatsApp og AI-samtaler. Flyt: **Configure → Investigate → Remediate → Maintain**.

4.9 eDiscovery

Finne, bevare og analysere elektronisk informasjon som bevis i juridiske saker.

Begrep	Betyr
Case	Samler søk og data for én sak
Search	Finner data i Exchange, Teams, SharePoint, OneDrive
Hold	Bevarer data så de ikke slettes
Review set	Samler data for gjennomgang
Export	Eksporterer funn
Search and delete	Finner og sletter skadelig innhold

Løsning	Nivå	Nøkkelfunksjoner
Content Search	Basic	Søke i Microsoft 365 og eksportere resultater
eDiscovery Standard	Standard	Cases, legal holds, custodian management

Løsning	Nivå	Nøkkelfunksjoner
eDiscovery Premium	Premium	Avansert analyse, AI-støttet gjennomgang, OCR, conversation threading, decryption

4.10 Audit

Logger bruker- og adminaktivitet. **Unified audit log** samler logger fra M365 (Teams, Exchange, SharePoint, OneDrive, Copilot). Søk via Purview-portalen, PowerShell (`Search-UnifiedAuditLog`) eller API.

	Standard	Premium
Retention	**180 dager** (på som standard)	Opptil **1 år** (10 år med tilleggslisens)
Ekstra	Søk og eksport til CSV	Egne retention policies, intelligente innsikter, høyere API-kapasitet

PASS OPP Studieguiden oppgir **90 dager** for Standard. Det er utdatert. Dine egne notater og eksamensnotatene sier 180 dager. Bruk **180**, men sjekk Learn.

4.11 Data Lifecycle Management og Records Management

- **DLM:** behold data så lenge det trengs, slett når det ikke lenger trengs.
- **Retention policy:** område- eller postkassenivå. **Retention label:** enkeltelementer. Tre varianter: **retain-only · delete-only · retain and then delete**. Retention label policy publiserer etiketter.
- Mailbox archiving · inactive mailboxes · Copilot-prompter og svar kan beholdes eller slettes via retention.
- **Records Management:** viktige dokumenter som må beholdes for juridiske/regulatoriske krav (file plans, disposition).

HUSK **Audit** = aktivitetslogger · **eDiscovery** = juridiske undersøkelser · **DLM** = oppbevaring og sletting · **Records** = viktige dokumenter og arkivkrav.

Sensitivity labels	Retention labels
Klassifiserer og **beskytter** (kryptering, vannmerke, tilgang)	Styrer **hvor lenge** data beholdes/slettes
Bruker eller automatisk. Dokumenter og e-post	Uavhengig av sensitivitet. Steder eller enkeltelementer

4.12 Data governance: Data Map og Unified Catalog

Data governance = at data er trygge, pålitelige, av god kvalitet og brukes riktig. Beskytter data **og** gjør dem nyttige.

	Data Map	Unified Catalog
Gjør	Skanner, oppdager og samler metadata. Klassifiserer sensitive data	Organiserer, finner og styrer data
Detaljer	Metadata: technical, business, semantic, operational. Hybrid og multicloud. Gir **ikke** tilgang til selve dataene	Governance domains · data products · glossary terms · critical data elements (CDE) · OKRs · access policies · søk (Copilot støtter naturlig språk) · health management · data quality

Begreper: federated governance · data access · data curation · data discovery · data health · data understanding.
Roller: data consumer · data owner (tilgang og kvalitet) · data steward (kvalitet og begreper) · central data office (regler og oppfølging).

HUSK **Data Map = samler metadata. Unified Catalog = gjør metadata nyttige og søkbare.**

4.13 Regelverk og ressursstyring i Azure

- **GDPR:** EUs personvernforordning. **Data Subject Requests (DSR):** enkeltpersoners forespørsler om egne data. Purview hjelper med å dokumentere etterlevelse.

Azure-verktøy	Gjør
Azure Policy	Håndhever regler på tvers av ressurser (f.eks. alle VM-er må ha kryptering)
Resource Locks	Hindrer utilsiktet sletting/endring

Azure-verktøy	Gjør
Azure Blueprints	Pakker policyer, roller og maler for rask, kompatibel utrulling. **Utfaset**, erstattet av Template Specs og Deployment Stacks. Kan likevel dukke opp i eldre øvespørsmål

5. Forvekslingspar (eksamensfeller)

Par	Forskjellen
AuthN vs. AuthZ	Hvem du er vs. hva du får gjøre
Entra vs. Entra ID	Produktfamilien vs. kjernetjenesten
AD DS vs. Entra ID	On-prem (Kerberos/LDAP) vs. sky (OAuth/SAML)
B2B vs. CIAM	Samarbeide med partnere vs. kunder i din app
Entra-roller vs. Azure RBAC	Styrer Entra-ressurser vs. Azure-ressurser
PIM vs. Access reviews	JIT-aktivering av admin-roller vs. periodisk gjennomgang
Identity Protection vs. Conditional Access	Oppdager risiko vs. håndhever svaret
Alert vs. incident	Ett signal vs. samling relaterte varsler
XDR vs. SIEM/SOAR	Korrelerer Microsofts Defender-signaler vs. samler logger bredt og automatiserer
CSPM vs. CWP	Forebygge (svakheter) vs. oppdage/stoppe angrep
DDoS Protection vs. WAF	Lag 3–4 vs. lag 7
NSG vs. Azure Firewall	Enkle regler per subnett/NIC vs. sentral, stateful, FQDN, threat intelligence
Application Gateway vs. Front Door	Regional vs. global WAF
SNAT vs. DNAT	Ut (privat → offentlig) vs. inn (offentlig → privat)
Site-to-site vs. point-to-site	Hele nettverket vs. én enhet
SIT vs. trainable classifier	Mønster vs. tema
Sensitivity vs. retention labels	Beskytte vs. beholde
DLP vs. IRM	Hindrer deling vs. oppdager risikofylt intern atferd
IRM vs. Adaptive Protection	Oppdager vs. justerer beskyttelse automatisk
Content vs. Activity explorer	Hvor data ligger vs. hva brukere gjør
Data Map vs. Unified Catalog	Samler metadata vs. gjør dem søkbare og styrt
Audit Standard vs. Premium	180 dager vs. opptil 1 år (10 år med tillegg)
Service Trust Portal vs. Defender	Sjekke Microsofts samsvar vs. oppdage trusler

6. Hurtigreferanse til eksamensdagen

Tema	Nøkkelfakta
Shared responsibility	Kunden eier ALLTID data, identiteter, tilgang
Zero Trust	Verify explicitly · least privilege · assume breach
MFA	Vet · har · er (minst to)
Entra ID	= Azure AD. Skybasert identitet og tilgang
Lisenser	P1 = Conditional Access · P2 = Identity Protection + PIM
Conditional Access	Signaler → beslutning → håndhevelse. Report-only for testing
PIM	Just-in-time. Eligible → Active
Defender for Cloud	CSPM + CWP. Azure, AWS, GCP, on-prem. Secure Score
Sentinel	Skybasert SIEM + SOAR. KQL, analytics rules, hunting, playbooks (Logic Apps)
Defender XDR	Office 365 · Endpoint · Cloud Apps · Identity. Portal: security.microsoft.com
DDoS / WAF	Lag 3–4 / lag 7
NSG	Lavest prioritetstall først. Standard: tillat VNet + lastbalanserer inn, nekt resten

Tema	Nøkkelfakta
Bastion	RDP/SSH over TLS port 443 fra portalen. Ingen offentlig IP på VM
Key Vault	Secrets · keys · certificates. Standard = programvare, Premium = HSM
Azure Firewall	Basic ~250 Mbps · Premium = IDPS (67 000+ signaturer) + TLS-inspeksjon
Compliance score	Compliance Manager, 0–100 %. Your points + Microsoft-managed points
Sensitivity labels	Kun én per element. Persistent, clear text
Adaptive Protection	Minor / Moderate / Elevated. Elevated: bevar slettet innhold 120 dager
Audit	Standard 180 dager · Premium 1 år (10 med tillegg)
Service Trust Portal	servicetrust.microsoft.com: SOC/ISO/FedRAMP-rapporter

7. Selvtest

Dekk til høyre kolonne og svar høyt. Gå gjennom flere ganger, og forklar med egne ord.

Spørsmål	Svar
Hva er de tre Zero Trust-prinsippene?	Verify explicitly · least privilege · assume breach
Hva er kundens ansvar i alle skymodeller?	Data, endepunkter, kontoer og tilgangsstyring
Hva er forskjellen på AuthN og AuthZ?	Hvem du er vs. hva du får gjøre
Hvilken lisens trengs for Conditional Access? Og for PIM?	Entra ID P1 · Entra ID P2 (eller Governance)
Hva er forskjellen på user risk og sign-in risk?	Kontoen kompromittert vs. denne innloggingen ikke gjort av eieren
Hva betyr eligible og active i PIM?	Kan aktivere vs. aktiv nå (tidsbegrenset)
Hva må til for SSPR i hybrid?	Password writeback
Når bruker du B2B, og når en external tenant?	B2B: partnere/gjester. External tenant: kunder i din egen app
Hvilke autentiseringsmetoder er phishing-resistente?	Windows Hello · FIDO2 · passkey (Authenticator) · CBA
Hva er forskjellen på Entra-roller og Azure RBAC?	Entra-ressurser (brukere, grupper) vs. Azure-ressurser (VM, lagring)
Hva gjør Entra Connect?	Synkroniserer on-prem AD DS til Entra ID (hybrid identitet)
Hva gjør Private Access? Og Internet Access?	Interne apper uten VPN · sikker internett/SaaS-tilgang
Hva står XDR for, og hva er formålet med Defender XDR?	Extended Detection and Response. Kobler data og varsler for å oppdage, undersøke og håndtere avanserte angrep
Hvilken Defender-tjeneste stopper phishing-e-post?	Defender for Office 365
Hvilken Defender-tjeneste beskytter endepunkter?	Defender for Endpoint
Hva er forskjellen på alert og incident?	Alert = ett signal. Incident = samling relaterte varsler/bevis
Hva betyr triage?	Vurdere og prioritere varsler etter alvorlighetsgrad
Hva står SIEM og SOAR for?	Security Information and Event Management · Security Orchestration, Automation and Response
Hva er forskjellen på Sentinel og Defender for Cloud?	Sentinel = SIEM/SOAR (logger, jakt, automatisering). Defender for Cloud = CSPM/CWP (sikkerhetsstatus og arbeidsbelastninger)
Hva bygges Sentinel-playbooks på?	Azure Logic Apps
Hvilket lag dekker DDoS Protection? Og WAF?	Lag 3–4 · lag 7
Hva er standardregelen for innkommende trafikk til en NSG?	Tillat fra VNet og lastbalanserer, blokker alt annet
Hvilken NSG-regel evalueres først?	Den med lavest prioritetstall
Hva gjør Bastion, og hvorfor trengs ingen offentlig IP?	RDP/SSH over TLS fra portalen. Bastion kobler til VM-ens private IP
Hva er forskjellen på Key Vault Standard og Premium?	Programvare- vs. HSM-beskyttede nøkler
Hva finner attack path analysis, og hvilken plan trengs?	Angriperens vei til verdifulle ressurser. Defender CSPM (betalt)
Hva er forskjellen på CSPM og CWP?	Forebygge (finne svakheter) vs. oppdage og stoppe angrep på arbeidsbelastninger

Spørsmål	Svar
Hvor mange sensitivity labels kan ett dokument ha?	Én
Hva er forskjellen på sensitivity label og retention label?	Beskytte vs. styre hvor lenge data beholdes
Hvilke DLP-handlinger finnes?	Warn · block with override · block · quarantine
Hva er Elevated i Adaptive Protection?	Høyeste risikonivå, strengeste tiltak
Hvor lenge beholder Audit Standard logger?	180 dager
Hva brukes Service Trust Portal til?	Se Microsofts revisjonsrapporter, sertifiseringer og compliancedokumentasjon
Hva er forskjellen på Data Map og Unified Catalog?	Samler metadata vs. gjør dem søkbare og styrt
Hva er forskjellen på DLP og Insider Risk Management?	Hindrer deling vs. oppdager risikofylt intern atferd

8. Avvik mellom kildene og hva du bør sjekke

Kildene sier ikke alltid det samme. Dette er forskjellene jeg fant, og hva jeg har valgt i dokumentet.

Tema	Hva kildene sier	Valg her
Audit Standard retention	Studieguiden: 90 dager. Egne notater/eksamensnotater: 180 dager	180 dager
Apper i PaaS (shared responsibility)	Studieguiden: Microsoft. Egne notater: kunde	Kunde. Microsofts figur markerer noen rader som delt, så sjekk figuren på Learn
Entra Connect	Studieguiden: «Azure AD Connect»	Entra Connect (tidligere Azure AD Connect)
B2C	Studieguiden: B2B/B2C. Egne notater: B2C ikke lenger for nye kunder	External ID (B2B + external tenant/CIAM)
DDoS-nivåer	Studieguiden: Basic/Standard. Egne notater: Network Protection / IP Protection	Network Protection / IP Protection
Purview-portal	Studieguiden: compliance.microsoft.com	Bare «Purview-portalen». Nyere materiell bruker purview.microsoft.com (sjekk)
Azure Blueprints	Eldre kilder: aktiv. Nyere: utfaset	Utfaset (Template Specs / Deployment Stacks)

Gjenstår før eksamen

- Sammenlign dette dokumentet med den **offisielle «skills measured»-listen** for SC-900 på Microsoft Learn. Eksamensoppdateringer endrer innholdet.
- Sjekk lisenskrav, Agent ID- og Security Copilot-status, og navn på portaler.
- Gjør Microsoft Learns gratis øvingseksamen (practice assessment) for SC-900 når du har lest alt én gang.

Slik gjør du SC-900 verdifull for jobbsøking

- **Nevn den på CV og LinkedIn.** Det viser bredde mot Microsoft-økosystemet, og mange norske arbeidsgivere bruker M365 og Azure.
- Vil du mot SOC: bruk litt tid i **Sentinel** og **Defender-portalen** i en gratis Azure-trial. Da har du noe konkret å vise i intervju, ikke bare et sertifikat.
- Gode intervjuspørsmål å øve på: *Forklar forskjellen på SIEM, SOAR og XDR · Hva er Zero Trust i praksis? · Hvordan stopper Conditional Access et kapret passord? · Hvorfor segmentere et nettverk?* (den siste kobler rett til CCNA).